



Authorization

Roles

The Home Connect API uses the [OAuth2](#) standard as defined in [RFC 6749](#) in order to grant 3rd party access to home appliances which are paired to a Home Connect user account. Every request has to be authorized by an access token as defined in [RFC 6750](#).

User (Resource Owner)

The owner of the home appliance. The home appliance must be paired to the user's Home Connect account.

Resource Server

The Home Connect system which enables the access to the user's home appliances.

Application (Client)

A 3rd party application with the intention to monitor or control user's home appliances.

Authorization Server

The Home Connect authorization server which issues access tokens to the client.

Authorization Scopes



If you choose a row all cells of this row are included. If you choose, for instance, *Dishwasher*, then you also get *Dishwasher-Monitor*, *Dishwasher-Control* and *Dishwasher-Settings*. The same inclusion applies to columns.

Note that you should always choose the minimum required set of scopes which is required by your application. This increases the acceptance by your customers.

	Monitor	Control	Images	Settings
Oven	Oven-Monitor	Oven-Control	-	Oven
Dishwasher	Dishwasher-Monitor	Dishwasher-Control	-	Dishwasher-Settings
Washer	Washer-Monitor	Washer-Control	-	Washer-Settings
Dryer	Dryer-Monitor	Dryer-Control	-	Dryer
WasherDryer	WasherDryer-Monitor	WasherDryer-Control	-	WasherDryer-Settings
FridgeFreezer	FridgeFreezer-Monitor	FridgeFreezer-Control	FridgeFreezer-Images	FridgeFreezer-Settings
Refrigerator	Refrigerator-Monitor	Refrigerator-Control	-	Refrigerator-Settings
Freezer	Freezer-Monitor	Freezer-Control	-	Freezer-Settings
WineCooler	WineCooler-Monitor	WineCooler-Control	-	WineCooler-Settings
CoffeeMaker	CoffeeMaker-Monitor	CoffeeMaker-Control	-	CoffeeMaker-Settings
Hob	Hob-Monitor	Hob-Control	-	Hob-Settings
Hood	Hood-Monitor	Hood-Control	-	Hood
CleaningRobot	CleaningRobot-Monitor	CleaningRobot-Control	-	CleaningRobot-Settings



Microwave	Microwave-Monitor	Microwave-Control	-	Micro Setti
AirConditioner	AirConditioner-Monitor	AirConditioner-Control	-	AirCc Setti

All available scopes are listed in the following:

Name	Description	Ac Pc Aç re
	Grants right to identify a home appliance under::	
IdentifyAppliance	• <i>/api/homeappliances</i> • <i>/api/homeappliances/{hald}</i>	
	Grants access to read resources for the given home appliance type under:	
*-Monitor	• <i>/api/homeappliances/{hald}/programs</i> • <i>/api/homeappliances/{hald}/status</i> • <i>/api/homeappliances/{hald}/events</i> • <i>/api/homeappliances/events</i>	
	Grants access to modify resources for the given home appliance type under:	
*-Control	• <i>/api/homeappliances/{hald}/programs</i> • <i>/api/homeappliances/{hald}/commands</i>	
	Grants access to read resources for the given home appliance type under:	
*-Images	• <i>/api/homeappliances/{hald}/images</i>	



- */api/homeappliances/{hald}/settings*

Grants access to read resources for all home appliance types under:

Monitor

- */api/homeappliances/{hald}/programs*
- */api/homeappliances/{hald}/status*
- */api/homeappliances/{hald}/events*
- */api/homeappliances/events*

Grants access to modify resources for all home appliance types under:

Control

- */api/homeappliances/{hald}/programs*
- */api/homeappliances/{hald}/commands*

Grants access to read resources for all home appliance types under:

Images

- */api/homeappliances/{hald}/images*

Grants access to read and modify resources for all home appliance types under:

Settings

- */api/homeappliances/{hald}/settings*

Grants access to read or modify all resources on ovens and warming drawers under:

Oven

- */api/homeappliances/**

Grants access to read or modify all resources on dishwashers under:

Dishwasher

- */api/homeappliances/**

Washer

Grants access to read or modify all resources on



- */api/homeappliances/**

Dryer

Grants access to read or modify all resources on dryers under:

- */api/homeappliances/**

WasherDryer

Grants access to read or modify all resources on washer dryers under:

- */api/homeappliances/**

FridgeFreezer

Grants access to read or modify all resources on fridge freezers under:

- */api/homeappliances/**

Refrigerator

Grants access to read or modify all resources on refrigerators under:

- */api/homeappliances/**

Freezer

Grants access to read or modify all resources on freezers under:

- */api/homeappliances/**

WineCooler

Grants access to read or modify all resources on wine coolers under:

- */api/homeappliances/**

CoffeeMaker

Grants access to read or modify all resources on coffee machines under:

- */api/homeappliances/**



Hob

Grants access to read or modify all resources on cooktops under:

- */api/homeappliances/**

Hood

Grants access to read or modify all resources on hoods under:

- */api/homeappliances/**

CleaningRobot

Grants access to read or modify all resources on cleaning robots under:

- */api/homeappliances/**

CookProcessor

Grants access to read or modify all resources on cook processors under:

- */api/homeappliances/**

Microwave

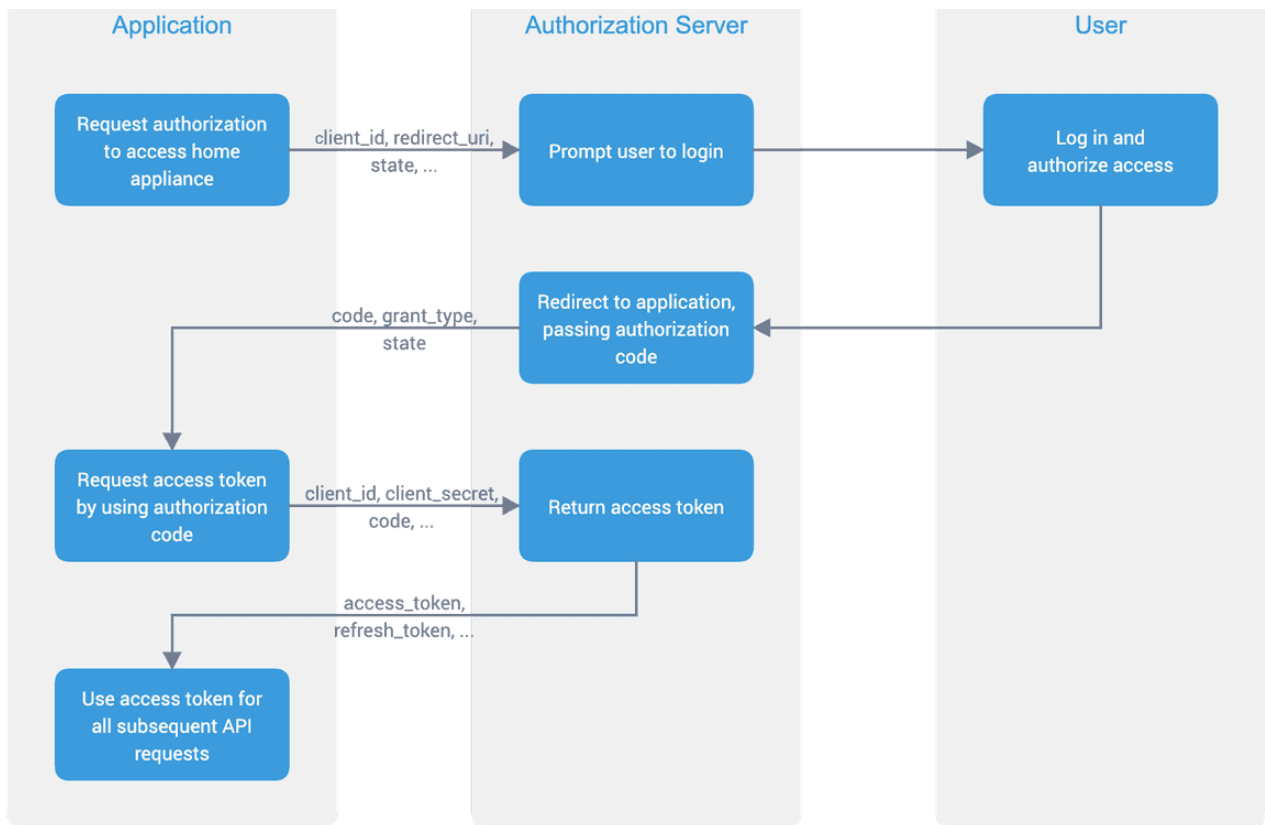
Grants access to read or modify all resources on microwaves under:

- */api/homeappliances/**

AirConditioner

Grants access to read or modify all resources on air conditioners under:

- */api/homeappliances/**



Before you can start with the authorization of your application, you need to [register your application](#) in the developer portal first. After registration, you get a client ID. You should generate one client ID per application.

Authorization Endpoint

Authorization Request

HTTP Method

GET

URL



client_id	Required. Client identifier which is generated after application registration. Length: 64 characters
redirect_uri	Optional. Redirect URI which is defined in registered application. If the <code>redirect_uri</code> parameter isn't used then the first defined redirect URI is used.
response_type	Required. Value must be code.
scope	Optional but recommended. Space separated (escaped by %20) list of permissions. The following permissions are <i>IdentifyAppliance</i> (always required), <i>MonitorAppliance</i> (see Authorization Scopes).
state	Optional but recommended. This parameter shall be used to prevent cross-site request forgery attacks. Use random number or hash of the session cookie and value. The value of the final redirect that the included value is the same as the value.
nonce	Optional. Random string that will be returned in the JWT token. It is used to mitigate replay attacks. Max length: 50 characters
code_challenge	Optional but required if <i>Proof Key for Code Exchange</i> is enabled in application settings. The code challenge is created by the client which is derived from the code verifier by using one of the following transform methods: <i>plain</i>: code_challenge = code_verifier <i>S256</i>: code_challenge = BASE64URL-ENCODE(SHA256(ASCII(code_verifier)))
code_challenge_method	Optional. Method which was used to create the code challenge from the code verifier. <i>plain</i> (default) <i>S256</i> (recommended)



Authorization Response

The request will return a HTML login page which has to be presented to the user. When the user presses *Login*, a HTML grant page is returned. This page informs the user about the requested scope. If the user grants access, an HTTP 302 redirect to the *redirect_uri* is returned which includes the authorization code as request parameter.

HTTP Status Code

Code	Short Description	Long Description
302	Found	Redirection in case of success or Authorization I
400	Bad Request	see Authorization Errors
503	Service Unavailable	see Authorization Errors

Response Header

- Content-Type: text/html

Query Parameters

Key	Value	Description
code	Required.	Code to be used in a subsequent access token request (see also Sect [RFC6749]). It expires after 10 minutes.
grant_type	Optional.	Type of the returned code, currently always authorization_code .
state	Optional.	State provided by the client in the authorization request.



Access Token Endpoint

Access Token Request

HTTP Method

POST

URL

<https://api.home-connect.com/security/oauth/token>

Request Header

- Content-Type: application/x-www-form-urlencoded

Body Parameters

Key	Value Description
grant_type	Required. Value must be authorization_code .
code	Required. The code retrieved from the preceding authorization request.
client_id	Required. Client identifier which is generated after application registration. Length: 64 characters
client_secret	Required. Secret of the client that requested the code. It is generated after c registration. Please note that this parameter is required for this flc Length: 64 characters



redirect_uri	used then the first defined redirect URI is used. Please note that it if the <i>redirect_uri</i> parameter was included in the authorization request.
	Optional but required if <i>Proof Key for Code Exchange</i> is enabled in application settings.
code_verifier	Code verifier which was used during code challenge creation on client. Please note that it is required if the <i>code_challenge</i> parameter was in the authorization request.

Example

> [Expand source](#)

Access Token Response

The request will return the access token and a refresh token in the HTTP body.

HTTP Status Code

Code	Short Description	Long Description
200	OK	Request succeeded
400	Bad Request	see Authorization Errors
403	Forbidden	see Authorization Errors
415	Unsupported Media Type	The request's Content-Type is not supported, expected <i>application/x-www-form-urlencoded</i>
503	Service Unavailable	see Authorization Errors

Response Header

- Content-Type: application/json



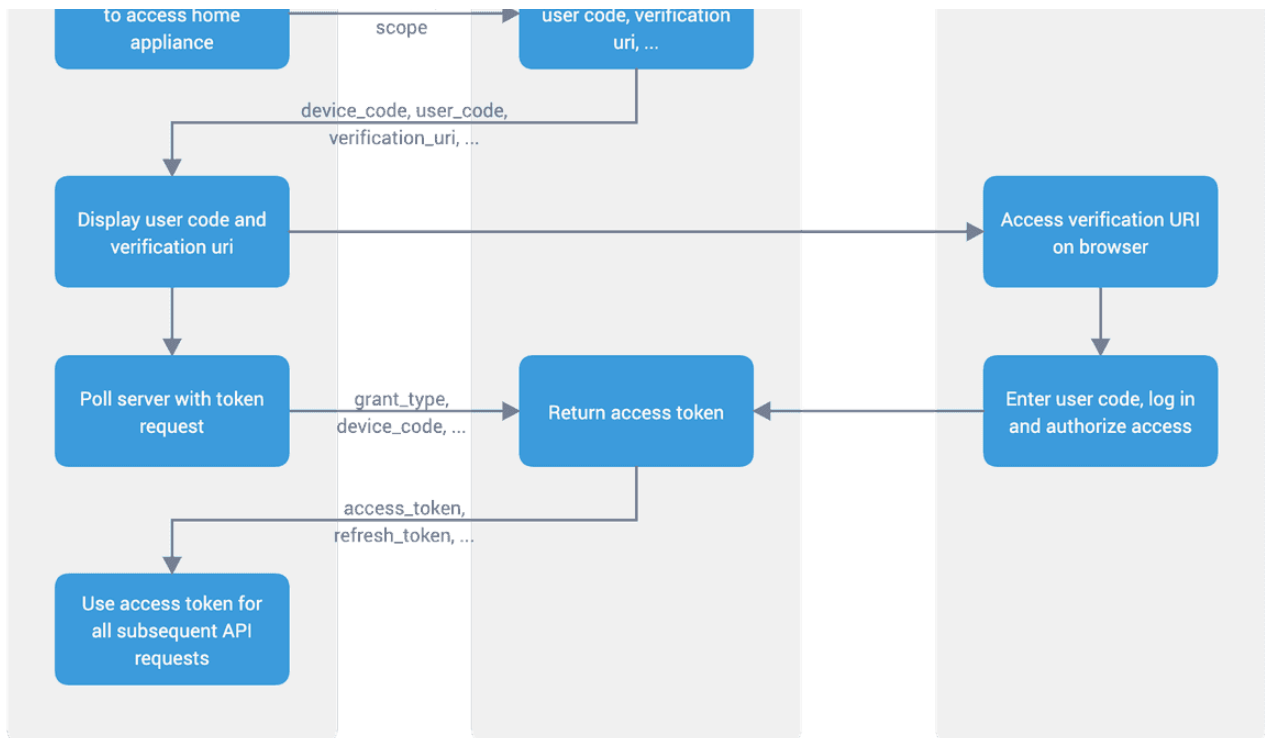
	Required.
access_token	Token to be used in subsequent Home Connect API requests. Max length: 4096, normally: ~ 1000 characters depending on the u
expires_in	Required. Expiration time of the access token and id_token in seconds, defa
scope	Required. Permissions requested by the client application separated by spac
refresh_token	Required. Token to be used to refresh access token (expires if it wasn't used days). Max length: 256, normally: ~ 125 characters
token_type	Optional. Type of the token, currently always Bearer .

Example

[> Expand source](#)

Device Flow

The Home Connect API supports the OAuth2 [Device Flow](#) as shown in the figure below:



Before you can start with the authorization of your application, you need to [register your application](#) in the developer portal first. After registration, you get a client ID. You should generate one client ID per client.

Device Authorization Endpoint

Device Authorization Request

HTTP Method

POST

URL

https://api.home-connect.com/security/oauth/device_authorization



Key	Value	Description
		Required.
client_id		Client identifier which is generated after application registration. Length: 64 characters
		Optional but recommended .
scope		Space separated (escaped by %20) list of permissions. Possible permissions: <i>IdentifyAppliance</i> (always required), <i>Monitor</i> , <i>Control</i> (see Authorization)

Example

[Expand source](#)

Device Authorization Response

The request will return the device code and user code in the HTTP body.

HTTP Status Code

Code	Short Description	Long Description
200	OK	Request succeeded
400	Bad Request	see Authorization Errors
415	Unsupported Media Type	The request's Content-Type is not supported, expected <i>application/x-www-form-urlencoded</i>
503	Service Unavailable	see Authorization Errors

Response Header

- Content-Type: application/json



user_code	Required. End-user verification code.
verification_uri	Required. End-user verification URI on the authorization server. It should be short and easy to remember as end-users will have to manually type it into their user-agent / webbrowser.
verification_uri_complete	Optional. Verification URI that includes the user_code (or other identifier) with the same function as the user_code), designed for textual transmission.
expires_in	Optional. Lifetime in seconds of the device_code and user_code, 300 .
interval	Optional. Minimum amount of time in seconds that the client SHOULD wait between polling requests to the token endpoint, 5 .

Example

[> Expand source](#)

User Interaction

see [Section 3.3 of Device Flow](#)

Access Token Endpoint



by using this endpoint. In addition to the error codes defined in [Section 3.2 of \[RFC6749\]](#), the following error codes are specified by the device flow for use in token endpoint responses:

- **authorization_pending**: authorization request is still pending as the end-user hasn't yet completed the user interaction steps. The client **SHOULD** repeat the Access Token Request to the token endpoint.
- **access_denied**: end-user denied the authorization request. The client **SHOULD** stop sending requests to this endpoint.
- **slow_down**: client is polling too quickly and **SHOULD** back off at a reasonable rate (see returned interval).
- **expired_token**: device_code has expired. The client **SHOULD** stop sending requests to this endpoint, it will need to make a new Device Authorization Request.

HTTP Method

POST

URL

<https://api.home-connect.com/security/oauth/token>

Request Header

- Content-Type: application/x-www-form-urlencoded

Body Parameters

Key	Value	Description
grant_type	Required. Set this parameter to urn:ietf:params:oauth:grant-type:device_code if the access token is to be requested with the device code preceding authorization request.	
device_code	Required. Device verification code which was returned by device authorization	



	Length: 64 characters
	Optional but recommended .
client_secret	Secret of the client that requested the code. It is generated after a registration. Length: 64 characters

Example

> [Expand source](#)

Device Access Token Response

The request will return the access token and a refresh token in the HTTP body.

HTTP Status Code

Code	Short Description	Long Description
200	OK	Request succeeded
400	Bad Request	see Authorization Errors
403	Forbidden	see Authorization Errors
415	Unsupported Media Type	The request's Content-Type is not supported, expected <i>application/x-www-form-urlencoded</i>
503	Service Unavailable	see Authorization Errors

Response Header

- Content-Type: application/json

Response Parameters



	Required.
access_token	Token to be used in subsequent Home Connect API requests. Max length: 4096, normally: ~ 1000 characters depending on the u
expires_in	Required. Expiration time of the access token and id_token in seconds, defai
scope	Required. Permissions requested by the client application separated by spac
refresh_token	Required. Token to be used to refresh access token (expires if it wasn't used days). Max length: 256, normally: ~ 125 characters
token_type	Optional. Type of the token, currently always Bearer .

Example

[> Expand source](#)

Refreshing an Access Token

Due to the limited access token lifetime of 86400 seconds (24 hours), the client has to request a new access token as soon as the access token has expired. This can be done by using the following token endpoint.



Access Token Refresh Request

HTTP Method

POST

URL

<https://api.home-connect.com/security/oauth/token>

Request Header

- Content-Type: application/x-www-form-urlencoded

Body Parameters

Key	Value Description
grant_type	Required. Value must be refresh_token .
refresh_token	Required. It is returned by previous token response.
client_id	Optional but recommended . Client identifier which is generated after application registration. Length: 64 characters
client_secret	Optional but recommended . Secret of the client that requested the code. It is generated after registration. Please note that this parameter is required for the authorization code grant flow . Length of 64 characters
scope	Optional. It can be used to reduce the original set of permissions. If not defi original scope will be kept.
expires_in	Optional. It can be used to reduce the time the live of the returned access to



Access Token Refresh Response

The request will return the new access token in the HTTP body.

HTTP Status Code

Code	Short Description	Long Description
200	OK	Request succeeded
400	Bad Request	see Authorization Errors
403	Forbidden	see Authorization Errors
415	Unsupported Media Type	The request's Content-Type is not supported, expected <i>application/x-www-form-urlencoded</i>
429	Too Many Requests	Too many token refreshes per minute or day
503	Service Unavailable	see Authorization Errors

Response Header

- Content-Type: application/json

Response Parameters

Key	Value	Description
id_token	Required.	Same as access token.
access_token	Required.	Token to be used in subsequent Home Connect API requests. Max length: 4096, normally: ~ 1000 characters depending on the implementation
expires_in	Required.	Expiration time of the access token and id_token in seconds, default is 3600



refresh_token	Required. Token to be used to refresh access token (expires if it wasn't used days). Max length: 256, normally: ~ 125 characters
token_type	Optional. Type of the token, currently always Bearer .

Example

➤ *Expand source*

Authorization Errors

In the following, the possible authorization errors are explained.

(Device) Authorization Endpoint

HTTP Status Codes

Code	Short Description	Long Description
302	Found	Redirection



503

Service Unavailable

Backend service currently not available

Error Cases

Error Cause	Code	Error	Error Description	Redirect
Backend service currently not available	503	temporarily_unavailable	Backend service currently not available	
Invalid request, client ID is missing	400	invalid_request	missing or invalid request parameters	
Repeated request parameter	400	invalid_request	repeated request parameters	
Invalid client ID	400	unauthorized_client	request rejected by client authorization authority (developer portal)	
Client is not allowed to use this OAuth flow	400	unauthorized_client	client not authorized for this oauth flow (grant_type)	
No redirect URI is defined in developer portal	400	unauthorized_client	client has no redirect URI defined	
Invalid client	400	unauthorized_client	client or	



authorized

Invalid request, response type is missing	302	invalid_request	missing or invalid request parameters
Unsupported response type	302	unsupported_response_type	given response_type not supported
Invalid HC account - please check configured test account	302	unauthorized_client	client has limited user list - user not assigned to client
Invalid scope	302	invalid_scope	given scope doesn't match requested scope
Login aborted	302	access_denied	login aborted by the user
Grant operation aborted	302	access_denied	grant operation aborted by the user

Redirection Example

> [Expand source](#)

JSON Example

> [Expand source](#)



.....

Code	Short Description	Long Description
400	Bad Request	e.g. invalid, missing or duplicate parameters
403	Forbidden	e.g. invalid user or terms of use must be accepted
415	Unsupported Media Type	The request's Content-Type is not supported, expected application/x-www-form-urlencoded
429	Too Many Requests	Too many token refreshes per minute or day
503	Service Unavailable	Backend service currently not available

Error Cases

Error Cause	Code	Error	Error Description
Backend service currently not available	503	temporarily_unavailable	Backend service currently not available
Missing parameter, e.g. client id, code or grant_type	400	invalid_request	missing or invalid request parameters
Repeated request parameter	400	invalid_request	repeated request parameter
Client ID and client secret is used in Basic Auth header and request body	400	invalid_request	Multiple authorization methods found
Unsupported grant type	400	unsupported_grant_type	grant method not supported
Invalid auth code or client ID	400	invalid_grant	invalid authorization code
Invalid client secret	400	unauthorized_client	client secret validation failed
Client token not allowed to refresh	400	invalid_token	client token not authorized for refresh



is still pending	400	authorization_pending	hasn't yet completed interaction steps
Client is polling too quickly	400	slow_down	client is polling too
Device code has expired or was used twice	400	expired_token	device authorization not found, expired
Missing or invalid redirect URI	400	invalid_grant	incorrect redirect_uri parameter
Invalid refresh token or client was revoked in the Home Connect app	400	invalid_grant	invalid refresh_token
Invalid scope, e.g. while the token is refreshed	400	invalid_scope	given scope doesn't match requested scope
Invalid HC account - please check configured test account	400	unauthorized_client	used HC account is not authorized for this
The user is currently or no longer found in the system. This may happen if user has been deregistered.	403	access_denied	invalid user
The user has to accept new TOCs or DPTs in the Home Connect app.	403	access_denied	terms of use must be accepted
Access token were refreshed too often (only 100 refreshes are allowed per day and 10 per minute)	429	429	The rate limit for refresh token requests was exceeded. Requests are blocked for the remaining period in seconds.



Next Chapter